Microsoft 365 Security Controls

Detailed Design and Implementation Plan

Target organization: 100 users | 2 administrators | Microsoft 365 enterprise security capabilities

Version 1.0 | 28 October 2026

> Licensing assumption: “Microsoft 365 E7” is treated as a customer label for a package with capabilities comparable to Microsoft 365 E5. Actual service plans must be validated before implementation.

1. Executive Summary

This design protects the tenant across five interdependent domains: identity, devices, messaging and applications, data, and detection and recovery. The design uses Zero Trust principles: verify explicitly, apply least privilege, and assume breach. The controls are ranked by expected risk reduction and dependency order rather than by ease of configuration.

Rank	Control domain	Primary outcome	Target maturity
1	Identity and privileged access	Prevent account and tenant takeover	Phishing-resistant administration; adaptive access for all users
2	Managed endpoints	Reduce ransomware, token theft, and unmanaged access	Intune-compliant devices with Defender for Endpoint
3	Email, collaboration, and applications	Reduce phishing, BEC, malware, and OAuth abuse	Defender for Office 365 plus controlled consent and sharing
4	Information protection	Limit leakage, oversharing, and retention failures	Simple label model, DLP, guest governance, and retention
5	Detection and response	Contain incidents and responses	Defender XDR operations, playbooks, and exercises

> Design principle: Use built-in Microsoft presets and automation wherever they are safe, minimize exceptions, pilot user-impacting controls, and outsource after-hours monitoring if two administrators cannot meet agreed response times.

2. Assumptions, Constraints, and Design Principles

2.1 Assumptions

- Approximately 100 active users, including two tenant administrators and a small number of executives, finance, HR, and other high-value users.
- Microsoft 365 cloud services are the primary collaboration platform; Windows endpoints are the majority, with limited macOS and mobile use.
- The tenant can use Microsoft Entra ID P2, Microsoft Intune, Microsoft Defender XDR components, Microsoft Defender for Office 365 Plan 2, and Microsoft Purview features. Entitlements will be confirmed in Microsoft 365 admin center under Billing > Licenses.
- The organization can nominate a business security owner and can require users to complete security registration and device enrollment.
- Any on-premises Active Directory or hybrid identity components will be reviewed separately because they materially affect identity and Defender for Identity design.

2.2 Constraints

- Only two administrators are available, so the design avoids excessive custom policies and manual daily tasks.
- Business interruption must be minimized. Conditional Access, DLP, Attack Surface Reduction, and mail controls will use report-only, audit, simulation, or pilot modes before enforcement.
- All emergency access and service dependencies must be validated before tenant-wide enforcement.
- India-specific privacy and contractual obligations may apply, but formal legal interpretation is outside this technical design.

2.3 Architecture principles

Principle	Design application
Verify explicitly	Use user risk, sign-in risk, authentication strength, device compliance, application sensitivity, and session context.
Least privilege	Separate admin identities, use PIM, remove standing roles, restrict local admin, and minimize application permissions.
Assume breach	Use EDR, session revocation, alerting, immutable audit evidence.
Fail safely	Maintain two emergency accounts, staged deployments, documented rollback, and named change owners.
Keep operations sustainable	Prefer Microsoft presets, a small label taxonomy, standard device profiles, and a single incident queue.

3. Target Security Architecture

The target architecture uses Microsoft Entra Conditional Access as the access policy engine. Identity signals and Microsoft Defender device risk feed access decisions. Microsoft Intune establishes device compliance. Microsoft Defender XDR correlates identity, endpoint, email, application, and cloud signals. Microsoft Purview applies data classification, DLP, and retention controls. Audit, incident processes, provide detection and resilience.

Layer	Primary services	Key enforcement
Identity	Microsoft Entra ID, Conditional Access, ID Protection, PIM	Authentication strength, risk policies, role activation, session controls
Endpoint	Microsoft Intune, Defender for Endpoint	Compliance, encryption, EDR, ASR, patching, local privilege controls
Messaging and apps	Defender for Office 365, Exchange Online, Teams, SharePoint, Entra enterprise apps	Safe Links, Safe Attachments, anti-phishing, SPF/DKIM/DMARC, app consent, external sharing
Data	Microsoft Purview Information Protection, DLP, retention	Labels, encryption, DLP policy tips and blocks, lifecycle controls
Operations	Microsoft Defender XDR, Purview Audits	Incident correlation, automated response, playbooks, investigations, restore tests

4. Control 1 - Identity and Privileged Access

Objective: prevent stolen credentials or sessions from becoming tenant compromise, while preserving recoverability and manageable user experience.

4.1 Identity segmentation

Identity type	Design
Standard user	One productivity account per person; no directory role; MFA required; managed-device access progressively enforced.
Administrator	Separate named admin account for each administrator; no routine email; phishing-resistant authentication; eligible roles through PIM.
Emergency access	Two cloud-only accounts; Global Administrator; long random credentials stored independently; excluded only from policies that could cause lockout; every use alerted.
Service/workload identity	Prefer managed identity or workload identity federation; otherwise certificate credentials; no shared user account; owner and expiry recorded.
Guest	Sponsor, purpose, expiration, access package or review where available; disabled or removed when no longer required.

4.2 Conditional Access policy set

Policy	Scope	Controls	Mode / sequence
CA-01 Block legacy authentication	All users; all resources; legacy client types	Block	Report-only 7 days, then enabled after exceptions resolved
CA-02 Require MFA for workforce	All users; all resources; emergency accounts excluded	Require MFA or approved authentication strength	Pilot, then staged enablement
CA-03 Protect administrators	Directory roles and admin accounts	Phishing-resistant authentication strength; approved devices where feasible	Enabled after admin registration
CA-04 Risky sign-ins	All users; medium/high sign-in risk	Require MFA; appropriate sign-in frequency	Report-only, then enabled
CA-05 Risky users	All users; high user risk	Require secure password change and MFA	Report-only, then enabled
CA-06 Require compliant devices	Admins and sensitive apps first	Require compliant device; approved mobile app controls as applicable	Pilot after Intune readiness
CA-07 Block unsupported platforms/locations	Unsupported device platforms; verified high-risk geography only	Block	Use only with business-approved travel and exception process

> Do not combine Security Defaults with a custom Conditional Access design. Maintain an exclusion register and review every exclusion monthly. Never exclude a broad user group merely to resolve a single application problem.

4.3 Privileged Identity Management

- Make Global Administrator, Privileged Role Administrator, Conditional Access Administrator, Exchange Administrator, SharePoint Administrator, Teams Administrator, Security Administrator, and Application Administrator eligible rather than permanently active.
- Use a maximum activation duration of four hours for high-impact roles and eight hours for lower-impact operational roles.
- Require MFA, justification, and ticket/change reference for activation. Require approval for Global Administrator and Privileged Role Administrator when operationally feasible.
- Alert on permanent role assignment, role activation outside business hours, emergency-account use, and changes to Conditional Access or application credentials.
- Complete a quarterly access review of privileged assignments and role-assignable groups.

4.4 Authentication methods

- Administrators: two FIDO2 security keys per administrator or FIDO2 plus Windows Hello for Business; prohibit SMS as the primary admin method.
- Priority users: FIDO2 or Windows Hello for Business, beginning with finance, payroll, executives, HR, and users authorized to change bank details.
- All other users: Microsoft Authenticator with number matching during transition, followed by phishing-resistant methods where practical.
- Use Temporary Access Pass for controlled onboarding and recovery. Require identity verification before issuing a pass.
- Registration target: 100% of active users with at least two approved methods; complete within 30 days.

4.5 Validation and rollback

Test	Pass condition
Normal user sign-in	MFA is requested and access operates from a compliant pilot device.
Legacy client test	Authentication is blocked and recorded in sign-in logs.
Admin portal test	Phishing-resistant authentication is required for privileged account.
Risk simulation / test user	Risk policy produces the expected control without affecting emergency access.
Emergency access test	Stored credential works, alerts fire, and activity is documented.
Rollback	Policy can be set to report-only or disabled by authorized administrator using a tested account.

5. Control 2 - Managed Endpoints and Endpoint Detection

Objective: allow corporate data only from devices with a known security posture, stop common malware behaviors, and automate containment of high-confidence endpoint threats.

5.1 Device groups and baselines

Ring	Population	Purpose	Deployment delay
Ring 0	Two administrators and test devices	Validate access, policy, recovery, and business-critical tools	Immediate
Ring 1	10-15 representative users	Pilot across departments and device types	3-7 days after Ring 0
Ring 2	Remaining users in groups of 20-25	Controlled production rollout	Weekly waves
Exception ring	Approved legacy or specialist devices	Compensating controls and remediation deadline	Time bound; monthly review

5.2 Required endpoint controls

Area	Target configuration
Enrollment	All company-owned Windows, macOS, iOS, and Android devices enrolled in Intune; ownership and primary user recorded.
Encryption	BitLocker or FileVault enforced; recovery material escrowed; removable-media policy defined.
Malware protection	Defender Antivirus cloud-delivered protection, behavior monitoring, real-time protection, network protection, and tamper protection enabled.
EDR	All supported endpoints onboarded to Defender for Endpoint; EDR in block mode and automated investigation/remediation enabled.
Firewall	Host firewall enabled on all profiles; inbound rules minimized and centrally managed.
Privilege	Users are standard users; Windows LAPS used for controlled local recovery; admin elevation governed.
Patching	Windows update rings; expedited updates for actively exploited vulnerabilities; third-party application patch process.
Compliance	Unsupported OS, disabled security controls, excessive patch age, root/jailbreak, or high Defender risk makes a device noncompliant.
Access	Conditional Access requires compliant devices for admins and sensitive workloads, then expands to all corporate data.

5.3 Attack Surface Reduction deployment

Start ASR rules in audit mode for at least 14 days. Resolve legitimate application dependencies, then use warn or block. Priority rules include blocking Office child processes, credential stealing from LSASS, executable content from email/webmail, abuse of vulnerable signed drivers, and untrusted USB execution. Exceptions must identify the application owner, device group, risk acceptance, and expiry date.

5.4 Patch and vulnerability objectives

Category	Target
Known exploited / emergency	Assess immediately; deploy within 48-72 hours where operationally possible
Critical without known exploitation	7 calendar days
High severity	14 calendar days
Medium severity	30 calendar days
Unsupported software or OS	Remove, upgrade, isolate, or formally accept risk with a deadline

6. Control 3 - Email, Collaboration, and Application Protection

Objective: reduce phishing, business email compromise, malware delivery, impersonation, malicious OAuth consent, and unsafe external collaboration.

6.1 Defender for Office 365 design

Capability	Configuration
Preset policies	Standard preset for all users; Strict preset for admins, executives, finance, payroll, HR, and payment-authorized users.
Safe Links	Enabled for email, Teams, and supported Office apps; track clicks; do not allow click-through for clearly malicious content.
Safe Attachments	Dynamic Delivery where suitable; block or quarantine malicious attachments; protect SharePoint, OneDrive, and Teams.
Anti-phishing	Mailbox intelligence, user impersonation, domain impersonation, safety tips, and protected users/domains.
Anti-spam / malware	Microsoft recommended settings; quarantine policies aligned with help-desk capacity; Zero-hour Auto Purge enabled.
User reporting	Built-in Report button; submissions reviewed every business day; feedback used for tuning and awareness.

6.2 Domain authentication

1. Inventory every service that sends email using the organization's domains, including Microsoft 365, CRM, payroll, marketing, ticketing, invoicing, and line-of-business applications.

2. Publish and validate SPF without exceeding lookup limits; remove stale senders.
3. Enable DKIM for every active accepted domain and configure third-party senders to align where possible.
4. Publish DMARC at p=none with aggregate reporting for discovery, then move to quarantine, and finally reject after legitimate sources align.
5. Assign an owner to review DMARC reports and unauthorized-source trends.

6.3 Enterprise application and consent governance

- Disable unrestricted user consent and enable an admin consent request workflow with a named reviewer and target response time.
- Quarterly review of enterprise applications, service principals, verified publisher status, owners, last sign-in, credentials, and permissions.
- Escalate applications requesting Mail.ReadWrite, Files.ReadWrite.All, Directory.ReadWrite.All, RoleManagement.ReadWrite.Directory, Application.ReadWrite.All, or equivalent high-impact permissions.
- Prefer workload identity federation or certificate credentials over client secrets. Set expiry alerts and record technical and business owners.
- Remove unused applications, stale credentials, unnecessary delegated grants, and abandoned publisher integrations.

6.4 Teams, SharePoint, OneDrive, and guest controls

Control	Target
Default sharing link	Specific people for sensitive sites; avoid anonymous links as the default.
Anonymous sharing	Disabled for finance, HR, legal, security, and administrative sites; restricted elsewhere based on business need.
Guest lifecycle	Sponsor and business purpose required; quarterly review; inactivity or expiration workflow.
Site ownership	At least two owners on critical Teams and SharePoint sites.
Teams meetings	Only intended attendees admitted automatically for sensitive meetings; presenter rights minimized; anonymous joining based on documented business need.
External forwarding	Block automatic forwarding to external domains unless explicitly approved and monitored.

7. Control 4 - Information Protection, DLP, and Retention

Objective: identify sensitive data, prevent accidental or malicious disclosure, govern external sharing, and retain or dispose of information according to business and legal requirements.

7.1 Classification model

Label	Purpose	Default handling
Public	Approved information intended for external distribution	No encryption; sharing permitted
Internal	Routine business information not intended for unrestricted public release	Organization-first sharing; external sharing permitted when needed
Confidential	Customer, employee, financial, contractual, credential, security, or regulated data	Restricted sharing; encryption or access controls where appropriate; stronger DLP

> Keep the taxonomy to three labels for the initial release. Add sublabels only when a clear legal, contractual, or operational requirement cannot be met by the base model.

7.2 DLP policy design

Policy tier	Examples	Initial action	Mature action
High confidence / severe	Payment card data, bank details, national identifiers, credentials, large HR or customer exports	Simulation, then block with incident alert	Block; controlled override only if justified
Moderate confidence	Contracts, commercial data, source code, bulk external sharing	Policy tip and audit	Warn or block based on business process
Behavioral / volume	Mass download, mass deletion, repeated overrides	Alert and investigate	Adaptive restriction or incident response

7.3 Retention and records

- Define retention with legal and business owners. Do not select periods solely because they are technically available.
- Use a short list of retention categories: routine collaboration, financial/contractual records, personnel records, and transitory content.
- Document how holds, investigations, employee departures, inactive mailboxes, and site closure are handled.
- Distinguish retention from backup: retention preserves content under policy; backup supports operational restoration and recovery from deletion, corruption, or administrative error.
- Review policy conflicts and disposition responsibilities before auto-deletion is enabled.

7.4 Privacy and governance safeguards

- Approve role access to Content Explorer, Activity Explorer, eDiscovery, and insider-risk data through least-privilege groups.
- Document notice, monitoring purpose, retention, and authorized reviewers before enabling employee-monitoring features.
- Engage legal/privacy stakeholders for obligations under contracts and applicable laws, including India's Digital Personal Data Protection framework where relevant.
- Keep an audit trail of DLP overrides, investigations, exports, and policy changes.

8. Control 5 - Detection, Incident Response, and Recovery

Objective: identify material incidents quickly, contain them with repeatable actions, preserve evidence, and restore critical Microsoft 365 services and data within agreed objectives.

8.1 Defender XDR operating model

Severity	Target acknowledgement	Target containment	Escalation
Critical	15-30 minutes during covered hours	1 hour for identity/device isolation where feasible	Both admins, business owner, external incident responder
High	1 hour	4 hours	Security owner and service owner
Medium	Same business day	2 business days	Assigned administrator
Low / informational	Weekly review	Risk-based	Backlog or tuning

> If the organization cannot provide coverage aligned to these targets, contract a Microsoft-focused managed detection and response provider. Do not create an unavailable 24x7 commitment on paper.

8.2 Priority alert catalogue

- Emergency-access sign-in or failed sign-in attempts.
- New Global Administrator, Privileged Role Administrator, Conditional Access Administrator, or permanent privileged role assignment.
- Conditional Access policy disablement, broad exclusion, or authentication-strength weakening.
- New application credential, high-privilege OAuth grant, or suspicious consent.
- High-risk user/sign-in, impossible travel, anomalous token, or unusual administrative location.
- Suspicious inbox rule, external forwarding, executive impersonation, or mass phishing delivery.
- Mass SharePoint/OneDrive download, deletion, encryption, or external sharing.
- Defender tamper alert, ransomware behavior, credential dumping, or high-risk endpoint.

8.3 Minimum incident playbooks

Scenario	Immediate actions
Compromised user	Disable or block sign-in as appropriate; revoke sessions; reset authentication; inspect sign-ins, inbox rules, forwarding, OAuth grants, sent mail, and affected files; notify stakeholders.
Compromised administrator	Activate emergency governance; revoke sessions; disable account; inspect role, policy, app, consent, and audit changes; rotate affected credentials; engage external responder.
Business email compromise	Secure identity; trace mail; remove malicious rules; identify affected recipients; contact finance and bank through trusted channels; preserve evidence.
Ransomware endpoint	Isolate device in Defender; secure identity; inspect lateral activity and cloud files; initiate clean rebuild and data recovery.
Malicious OAuth app	Disable service principal; revoke grants and sessions; identify consenting users and accessed data; rotate related secrets; search for persistence.
Mass deletion	Contain identity/device; preserve audit evidence; stop sync if needed; restore through native recovery or backup; validate integrity.

9. Implementation Plan

Phase	Primary activities	Exit criteria
Mobilize	Validate licenses; assign owners; inventory identities, devices, apps, domains, sites, guests, and existing controls; establish change and incident registers.	Approved scope, dependency inventory, two emergency accounts, documented rollback owners.
Identity first	Separate admin accounts; phishing-resistant admin authentication; CA report-only; MFA registration; block legacy authentication; consent restrictions.	Admins protected; pilot successful; emergency access tested; no unresolved critical legacy dependency.
Endpoint and email	Intune/Defender pilot and rollout; encryption; EDR; update rings; Defender for Office presets; SPF/DKIM; DMARC discovery; app review.	At least 90% endpoints onboarded; priority users under Strict mail protection; legitimate senders inventoried.
Data and operations	Labels; DLP simulation; sharing review; guest governance; Defender XDR queue; playbooks; backup selection.	Labels piloted; high-severity alerts routed; first playbooks approved; backup design accepted.
Enforce and prove	Compliant-device access expansion; ASR enforcement; DLP high-confidence controls; DMARC quarantine/reject as ready; restore test; tabletop.	Documented tests passed; residual risks accepted; operational handover completed.

10. Roles and Responsibilities

Activity	Business owner	Admin 1	Admin 2	MSP / consultant	Data owners
Approve risk and policy	A	C	C	C	C
Implement and test controls	I	R	R	C	C
Daily incident review	I	R	R	C	I
Critical incident leadership	A	R	R	C/R	C
Data classification and retention	A	C	C	C	R
Quarterly access reviews	A	R	R	C	C
Recovery tests	I	R	R	C	C

R = Responsible, A = Accountable, C = Consulted, I = Informed.

11. Security KPIs and Acceptance Criteria

Measure	90-day target	Ongoing target
Active-user MFA registration	100%	Maintain >= 98%; exceptions investigated
Privileged users with phishing-resistant authentication	100%	100%
Standing Global Administrators	No daily-use account; only approved emergency model	Quarterly review

Measure	90-day target	Ongoing target
Legacy authentication	Zero successful interactive sign-ins	Zero
Managed/endpoints onboarded	>= 95% company-owned active devices	>= 98%
Disk encryption	100% supported corporate laptops	100%
Critical vulnerabilities	Within 7 days; exploited issues faster	48-72 hours for actively exploited where feasible
High-severity Defender incidents	Reviewed within 1 hour during coverage	>= 95% within SLA
Critical sites with two owners	100%	100%
Guest/app access review	Initial review complete	Quarterly
Restore validation	Mailbox, OneDrive, and SharePoint test completed	Quarterly
CA/DLP/ASR exceptions	Owner and expiry recorded	Monthly review; no expired exception

12. Key Risks, Tradeoffs, and Mitigations

Risk / tradeoff	Impact	Mitigation
Conditional Access lockout	Tenant administration disruption	Two tested emergency accounts; staged deployment; exclude only where necessary; documented rollback.
User friction from MFA/device compliance	Support load and lost productivity	Pilot, communication, self-service guides, Temporary Access Pass, multiple authentication methods.
ASR or DLP false positives	Business application or data-flow disruption	Audit/simulation mode, representative pilots, scoped exceptions with expiry.
Email false positives	Delayed or quarantined legitimate mail	Preset policies, protected-user tuning, submission workflow, mail-flow review.
DMARC blocks real senders	Failed business communication	Sender inventory, reporting period, staged none/quarantine/reject rollout.
Two-admin capacity	Unreviewed alerts and configuration drift	Automation, presets, single queue, clear SLAs, managed detection or Microsoft partner support.
Over-retention	Higher discovery cost and privacy exposure	Legal approval, minimal retention taxonomy, disposition review.
Backup compromise	Inability to recover	Separate identities, MFA, least privilege, immutable options where available, quarterly restore tests.

13. Test and Assurance Plan

Test stage	Required evidence
Pre-change	Exported configuration, impact analysis, pilot members, rollback steps, approver, test cases.
Technical validation	Sign-in logs, audit logs, Defender alerts, Intune status, message trace, DLP event, or restore report proving expected behavior.
User acceptance	Pilot confirmation from finance, HR, executives, and representative standard users.
Security assurance	Secure Score trends, Microsoft Defender exposure review, CISA ScubaGear baseline assessment, exception review.
Operational acceptance	Runbooks, support guide, escalation contacts, role coverage, dashboard, review calendar.
Post-change	Seven-day enhanced monitoring and documented closure of incidents or unexpected impact.

14. Operational Review Schedule

Frequency	Activities
Daily business days	Review critical/high Defender incidents, user-reported phishing, risky users/sign-ins, and service health.
Weekly	Review device noncompliance, vulnerability exposure, failed backups, mail quarantine trends, and open security exceptions.
Monthly	Review Conditional Access exclusions, privileged changes, application credentials, Secure Score backlog, DLP overrides, patch SLA, and policy drift.
Quarterly	Access reviews for roles, guests, applications, and sensitive sites; emergency-account test; restore test; CISA ScubaGear; incident tabletop.
Annually	Architecture review, risk assessment, data classification review, penetration/security assessment scope, vendor/MDR review, and full recovery exercise.

15. Reference Architecture and Guidance

- **Microsoft Zero Trust deployment plan with Microsoft 365:** https://learn.microsoft.com/en-us/security/zero-trust/microsoft-365-zero-trust
- **Microsoft Intune Zero Trust deployment approach:** https://learn.microsoft.com/en-us/intune/fundamentals/zero-trust-deployment
- **Microsoft Entra Conditional Access deployment planning:** https://learn.microsoft.com/en-us/entra/identity/conditional-access/plan-conditional-access
- **Microsoft Defender XDR prerequisites:** https://learn.microsoft.com/en-us/defender-xdr/prerequisites
- **Microsoft Defender XDR enablement:** https://learn.microsoft.com/en-us/defender-xdr/m365d-enable
- **Microsoft 365 security and compliance licensing guidance:** https://learn.microsoft.com/en-us/office365/servicedescriptions/microsoft-365-service-descriptions/microsoft-365-tenantlevel-services-licensing-guidance/microsoft-365-security-compliance-licensing-guidance
- **CISA Secure Cloud Business Applications (SCuBA):** https://www.cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project

Appendix A - Implementation Checklist

☐ Validate actual service plans and administrator roles.
☐ Create and test two cloud-only emergency access accounts.
☐ Create separate administrative identities and register two phishing-resistant methods.
☐ Deploy Conditional Access in report-only mode and review sign-in impact.
☐ Complete user MFA registration and enforce legacy-authentication block.
☐ Configure PIM and privileged access reviews.
☐ Enroll devices in Intune and onboard to Defender for Endpoint.
☐ Enable encryption, EDR, firewall, tamper protection, update rings, and ASR pilots.
☐ Apply Defender for Office 365 Standard and Strict presets.
☐ Validate SPF and DKIM and implement staged DMARC enforcement.
☐ Disable unrestricted user consent and review enterprise applications.
☐ Review external sharing, guests, site ownership, and forwarding.
☐ Publish three sensitivity labels and pilot DLP in simulation mode.
☐ Define retention and backup/recovery requirements.
☐ Configure Defender XDR incident queue, alerts, SLAs, and playbooks.
☐ Complete restore test, tabletop exercise, ScubaGear assessment, and handover.